

Risk List

Список рисков

1. Introduction (Введение)

Документ содержит перечень рисков проекта разработки SCMS, их оценку и стратегии смягчения. Регулярный review рисков проводится Project Manager ежемесячно.

1.1 Purpose (Назначение)

Идентифицировать, оценить и спланировать меры по управлению рисками проекта SCMS. Обеспечить готовность команды к нештатным ситуациям.

1.2 Scope (Область применения)

Риски, связанные с разработкой, внедрением и эксплуатацией SCMS. Включены технологические, бизнес-юридические, ресурсные и эксплуатационные риски.

1.3 Definitions, Acronyms, and Abbreviations (Определения и аббревиатуры)

Термин / Аббревиатура	Определение	Используется в документах
SCMS	Sleeving Clinic Management System — разрабатываемая система.	Все документы проекта
Stack / Кортикальный стек	Устройство хранения сознания, имплантируемое в затылок.	Vision, SRS, Glossary
Sleeve	Клонированное или подобранное тело для переноса сознания.	Vision, SRS, Glossary
Meth	Сверхбогатый клиент клиники, владелец множества стеков.	Vision, SRS, Glossary
Needlecast	Процесс передачи сознания из стека в нейроны нового тела.	Vision, SRS, Glossary
DHF	Digital Human Freight — цифровые данные сознания.	Vision, SRS, Glossary
Stack Shock	Психосоматический шок после переноса сознания.	Vision, SRS, Glossary
FR	Functional Requirement — функциональное требование.	SRS, SAD, TestPlan

RBAC	Role-Based Access Control — ролевая модель доступа.	SRS, SAD
2FA	Two-Factor Authentication — двухфакторная аутентификация.	SRS, Glossary
MTTR	Mean Time To Recovery — среднее время восстановления системы.	SRS, SDP, TestPlan
Audit Log	Неизменяемый журнал всех операций в системе.	SRS, SAD, Glossary
NDA	Non-Disclosure Agreement — соглашение о неразглашении.	Glossary

Детальные определения всех терминов приведены в документе «Glossary (Глоссарий)» проекта SCMS.

1.4 References (Ссылки)

- SRS (Спецификация требований) проекта SCMS, версия 1.0.
- SDP (План разработки) проекта SCMS, версия 1.0.

1.5 Overview (Обзор документа)

Раздел 2 содержит детальное описание каждого риска: вероятность, серьёзность, описание, влияние, признаки, стратегия смягчения и план действий при наступлении.

2. Risks (Риски)

2.1 R1: Технический долг и снижение качества кода

2.1.1 Risk Magnitude or Ranking (Вероятность появления и серьёзность)

Вероятность: Высокая. Серьёзность: Средняя.

2.1.2 Description (Описание)

В условиях жёсткого дедлайна (4 месяца) и малой команды (2 разработчика) возникает соблазн сокращать рефакторинг, пропускать code review и писать «быстрые» решения. Технический долг накапливается, что замедляет разработку в поздних итерациях и увеличивает количество дефектов.

2.1.3 Impacts (Влияние)

- Замедление добавления новых функций из-за сложности поддержки кода.
- Рост количества дефектов в уже работающих модулях.
- Невозможность передать код другому разработчику без длительного погружения.

2.1.4 Indicators (Признаки проявления)

- Увеличение времени на реализацию типовой задачи от итерации к итерации.
- Частые баги при добавлении новых функций в существующие модули.
- Отсутствие unit-тестов, низкое покрытие кода.

2.1.5 Mitigation Strategy (Стратегия смягчения)

- Code review обязателен для всех изменений — оба разработчика проверяют код друг друга.
- Выделение времени на рефакторинг в каждой итерации (до 20% спринта).
- Использование статического анализа кода (SonarQube, Checkstyle) в CI/CD.

2.1.6 Contingency Plan (Стратегия наступления)

- Приоритизация: рефакторинг критических модулей (аудит-лог, данные клиентов) в первую очередь.
- Снижение планки качества для некритичных функций ради соблюдения сроков.

2.2 R2: Утечка конфиденциальных данных клиентов

2.2.1 Risk Magnitude or Ranking (Вероятность и серьезность)

Вероятность: Средняя. Серьёзность: Критическая.

2.2.2 Description (Описание)

Несанкционированный доступ к данным клиентов (личная информация, история операций, медицинские записи) через уязвимости в системе, перехват трафика или инсайдерские действия. Для клиник уровня Meth компрометация данных означает потерю репутации и судебные иски.

2.2.3 Impacts (Влияние)

- Юридические иски от клиентов, компенсации до 50 млн кредитов.
- Отзыв лицензии клиники регулятором (Протекторат Бей-Сити).
- Потеря доверия и закрытие бизнеса.

2.2.4 Indicators (Признаки проявления)

- Необычная активность в audit-log (множественные неудачные попытки входа).
- Запросы к данным с IP-адресов за пределами сети клиники.
- Срабатывание IDS/IPS системы безопасности.

2.2.5 Mitigation Strategy (Стратегия смягчения)

- Шифрование всех чувствительных данных (TLS для передачи, AES для хранения).
- Аутентификация 2FA для всех учётных записей.
- RBAC: строгое разграничение доступа по ролям сотрудников.
- Аудит-лог с однократной записью (append-only), доступный только администратору.

2.2.6 Contingency Plan (Стратегия наступления)

- Немедленная блокировка скомпрометированной учётной записи.
- Запуск расследования: анализ audit-log, идентификация источника утечки.
- Уведомление затронутых клиентов и регулятора.
- Смена всех ключей шифрования и паролей.

2.3 R3: Срыв сроков разработки

2.3.1 Risk Magnitude or Ranking (Вероятность и серьезность)

Вероятность: Высокая. Серьёзность: Средняя.

2.3.2 Description (Описание)

Невыполнение плана разработки в установленные сроки (4 месяца) из-за недооценки сложности, изменения требований, технических проблем или низкой производительности. Учитывая малый размер команды, любая задержка критична.

2.3.3 Impacts (Влияние)

- Невозможность завершить все запланированные функции к дедлайну.
- Сжатие фазы тестирования (риск пропуска критических дефектов).
- Недовольство заказчика, потеря репутации команды.

2.3.4 Indicators (Признаки проявления)

- Отставание от графика >10% в итерации.
- Незавершённые задачи переходят в следующий спринт.
- Частые переоценки трудозатрат на задачи.

2.3.5 Mitigation Strategy (Стратегия смягчения)

- Приоритизация требований: критичные функции реализуются в первую очередь.
- Еженедельный review прогресса с заказчиком.
- Буфер времени: 2 недели на непредвиденные задержки.

2.3.6 Contingency Plan (Стратегия наступления)

- Пересмотр плана: перемещение некритичных функций в следующий релиз.
- Фокус на рабочем MVP с базовым функционалом вместо полного набора функций.

2.4 R4: Недостаточное тестирование и регрессионные ошибки

2.4.1 Risk Magnitude or Ranking (Вероятность и серьезность)

Вероятность: Высокая. Серьёзность: Высокая.

2.4.2 Description (Описание)

В команде нет выделенного QA-инженера — тестирование выполняют те же 2 разработчика. При сжатии сроков тестирование страдает в первую очередь: unit-тесты не пишутся, регрессионное тестирование пропускается, критические дефекты уходят в продакшен.

2.4.3 Impacts (Влияние)

- Критические дефекты в модулях аудит-лога и данных клиентов (юридические риски).
- Потеря данных или некорректная генерация сертификатов.
- Нестабильная работа системы в демонстрациях заказчику.

2.4.4 Indicators (Признаки проявления)

- Падение покрытия кода тестами ниже 30%.
- Пропуск этапа тестирования в итерации из-за нехватки времени.
- Повторное возникновение ранее исправленных багов.

2.4.5 Mitigation Strategy (Стратегия смягчения)

- Автоматизированное тестирование: unit + smoke-тесты в CI/CD на каждый коммит.
- Определение критического функционала (core-модули), обязательного к тестированию.
- Чек-лист регрессионного тестирования перед каждым релизом.

2.4.6 Contingency Plan (Стратегия наступления)

- Приоритетное исправление критических дефектов перед добавлением новых функций.
- Временное привлечение внешнего тестировщика (студент-стажёр).

2.5 R5: Технические проблемы интеграции и развёртывания

2.5.1 Risk Magnitude or Ranking (Вероятность и серьезность)

Вероятность: Средняя. Серьёзность: Средняя.

2.5.2 Description (Описание)

Сложности при интеграции backend (Spring Boot), frontend (React) и базы данных (PostgreSQL), а также при развёртывании на сервере helios.cs.ifmo.ru (FreeBSD). Отличия окружения разработки от продакшена могут вызвать неожиданные ошибки.

2.5.3 Impacts (Влияние)

- Задержка развёртывания, невозможность показать работающий продукт к демо.
- Потеря времени на отладку инфраструктурных проблем.
- Нестабильная работа системы на целевом сервере.

2.5.4 Indicators (Признаки проявления)

- Различия в поведении приложения на локальной машине и на сервере.
- Ошибки при сборке Docker-образов.
- Проблемы с сетевыми портами и правами доступа на helios.

2.5.5 Mitigation Strategy (Стратегия смягчения)

- Контейнеризация через Docker Compose — единое окружение для разработки и сервера.
- CI/CD: автоматическая сборка и тестирование при каждом push.
- Раннее развёртывание прототипа на сервере (фаза Elaboration) для выявления проблем.

2.5.6 Contingency Plan (Стратегия наступления)

- Откат к предыдущей стабильной версии при критических ошибках.
- Привлечение DevOps-специалиста (внешний консультант) для настройки сервера.
- Временное использование альтернативного окружения (например, облачный сервер).